LABORATUVAR 3 · ARMA MANTAR BARİYER · KİMYA TESİSİ GİRİŞİ

Threat & Risk + Risk Matrix

Çıktı: Risk Register

Ad Soyad Mehmet Onur Boyraz · 245541023 | Grup | Tarih 19.10.2026

Kavram: Senaryo beş parçadır: **kim → hangi kapı → ne yapar → zincir → FİZİKSEL sonuç**. Skor = **L × S × E** (her biri 1–3). **Kural:** S = 3 ise skor düşük olsa bile senaryo öne alınır; insana zarar görünür kalmalı.

Arma'nın kapıları (ipucu, LAB 2'den)

Paylaşılan Arma Mobil hesabı (internet) · 4G router port yönlendirme · Arma Kart HTTP/80 varsayılan parola · kulübe Wi-Fi (parola duvarda) · 433 MHz sabit kodlu RF kumanda · kulübe PC: TeamViewer + kilitsiz USB · plaka kamerası varsayılan parola V — *fiziksel sonuç adayları: bariyerin yaya, motosikletli ya da aracın altında yükselmesi; yanlış anda inip düşmanca aracı tank sahasına sokması; bakımda beklenmedik hareket.*

L · olasılık
1 = özel bilgi + fiziksel erişim + doğru zamanlama gerekir
2 = bilinen zayıflık; yakınlık ya da orta beceri
3 = internetten; bilinen parola ya da hazır araçla

S · şiddet
1 = maddi hasar, hizmet kesintisi
2 = hafif–orta yaralanma
3 = ağır/kalıcı yaralanma, ölüm ya da çoklu can kaybı

E · maruziyet
1 = nadiren (yılda birkaç bakım)
2 = gün içinde aralıklı
3 = sürekli (24/7 trafik, şeritte yaya)

Görev — üç senaryo kurun ve puanlayın

Senaryo (kim → kapı → ne yapar → zincir → fiziksel sonuç)	L	S	E	Skor	Öncelik
S1 · Uzaktan "hayalet operatör" KİM: İşten ayrılmış eski vardiya amiri; paylaşılan parola hiç değişmedi V KAPI: D1 Arma Mobil: "nerede olursanız olun" kontrol G, MFA yok V NE YAPAR: Yoğun saatte bariyerleri rastgele aralıklarla yükseltip indirir ZİNCİR: Arma bulutu → 4G port yönlendirme → Arma Kart; loop yayayı görmez, fotosel bypass'ta → SF-1 durduramaz FİZİKSEL SONUÇ: Hattaki yaya ya da motosikletli çarpılır, fırlatılır → ağır yaralanma ya da ölüm	3	3	3	27	Kritik
S2 · Kaydet-oynat ile kapı açma KİM: Organize saldırgan grup KAPI: 9 · RF kumanda alıcısı, 433 MHz sabit kod V NE YAPAR: Birkaç gün kapı yakınında ucuz bir SDR ile görevlinin "aç" sinyalini kaydeder, gece tekrar oynatır ZİNCİR: RF alıcı → Arma Kart → üç bariyer iner; komut meşru görünür, kim gönderdi kaydı yok FİZİKSEL SONUÇ: Patlayıcı yüklü araç tank sahasına ulaşır → patlama / zehirli gaz bulutu → çalışanlar ve çevre halkı	2	3	2	12	Yüksek
S3 · Bakımda beklenmedik hareket KİM: Hedefsiz zararlı yazılım (kilitsiz USB) ya da TeamViewer'dan giren fırsatçı KAPI: 13 · Kulübe PC: kilitsiz USB, 7/24 TeamViewer V NE YAPAR: Arma WOC üzerinden bariyerlere aç/kapat komutları gönderir ("deneme" ya da fidye öncesi keşif) ZİNCİR: WOC → C3 (bugün filtresiz) → Arma Kart; bakımda LOTO uygulanmamış, ünite enerjili FİZİKSEL SONUÇ: Çukurda çalışan teknisyenin eli ya da kolu bariyer ile zıvana arasında ezilir	1	3	1	3	Düşük ⚑ S = 3 → öne alınır

Kritik 18–27 | Yüksek 9–17 | Orta 4–8 | Düşük 1–3 | ⚑ = S = 3 bayrağı

1 **En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: neden bu?**

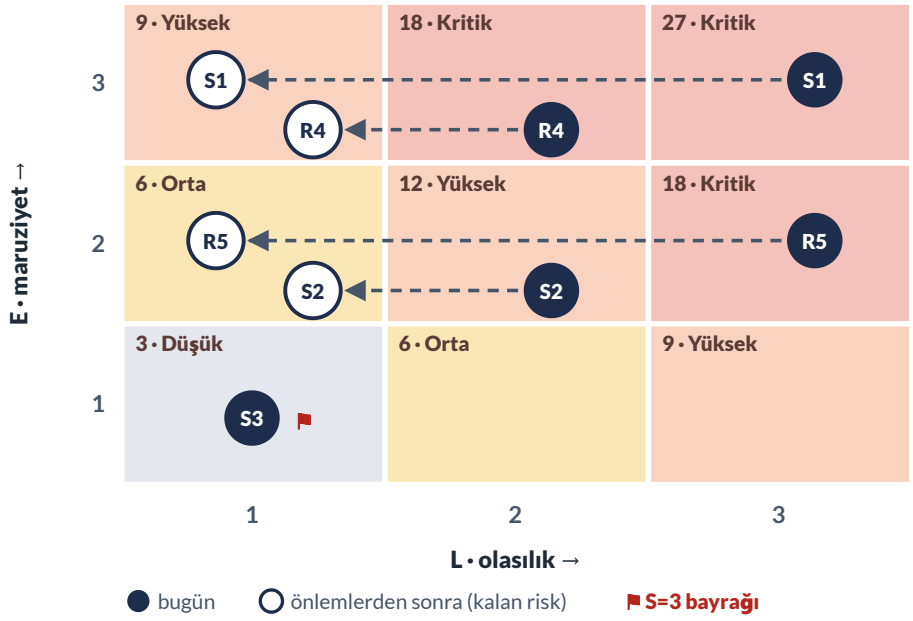
> **S1 (27, Kritik):** internetten, bilinen bir parolayla ve hiçbir kapıya takılmadan bariyeri hareket ettirebiliyor; yayayı koruyacak iki sensörden biri (loop) yayayı görmüyor, diğeri (fotosel) bypass'ta — yani insan ile hidrolik kuvvet arasında hiçbir şey kalmıyor.

2 **S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?**

> **Evet: S3** (L1 · S3 · E1 = 3, bant olarak "Düşük"). Skoru düşük çünkü bakım yılda birkaç kez yapılıyor ve saldırının o ana denk gelmesi gerekiyor. Ama gerçekleşirse sonuç bir uzvun kaybı. Görünür kılmak için:
>
> 1. **Bayrak:** register'da "⚑ S=3" ile Yüksek önceliğe çekildi. Bayrak skor düşünce değil, yalnız emniyet testleri geçince kapanır.
> 2. **Prosedür:** bakım talimatına LOTO + panodaki anahtarlı "bakım modu" eklenir; bu mod uzaktan gelen her komutu reddeder. Her bakımda kontrol listesiyle doğrulanır.
> 3. **Tatbikat:** yılda bir, bakım modundayken WOC'tan komut gönderilir; bariyerin kıpırdamadığı kanıtlanır ve kayda geçer.
> 4. **Raporlama:** yönetim gözden geçirmesinde S=3 senaryolar skordan bağımsız, ayrı bir listede raporlanır.

Altın kuralın uygulaması: "Arma Mobil raporları sızdı" tek başına bir veri bulgusudur, emniyet bulgusu değil. Bir adım daha gidince: raporlardaki giriş saatleri ve plakalar tanker trafiğinin desenini verir → saldırgan S1'i ya da S2'yi en yoğun ana zamanlar → hattaki yaya yaralanır ya da düşmanca araç bir tankerin arkasından tesise girer.

Risk matrisi — S = 3 düzleminde önce → sonra



Matristen çıkan üç sonuç

Siber önlemler okları sola iter:
MFA, kişisel hesap, kayan kod, jump server olasılığı (L) 1'e indirir. Hiçbiri bir oku aşağı indirmez; maruziyet (E) aynı kalır.

E'yi düşürmenin yolu fizikseldir:
yaya geçidini araç şeridinden ayırmak E'yi 3'ten 2'ye indirir. Böylece S1 ve R4 de Yüksek'ten Orta'ya iner.

S hiçbir senaryoda değişmez:
bu makinede şiddet hep 3. S=3 kuralı yüzünden hiçbir senaryo listeden düşmez; her biri ancak emniyet fonksiyonu testleriyle kapanır.

R4 ve R5, register'a eklenen iki senaryodur; ayrıntıları 3. sayfada.

Çıktı — Risk Register

Görevdeki üç senaryoya iki senaryo daha ekledik: R4, emniyet fonksiyonunun dijital ayarlarını hedefliyor; R5 ise emniyet fonksiyonunun güvenliğe karşı kullanılmasını gösteriyor. Sıralama skora göre; ⚑ bayraklı satır S=3 kuralıyla öne çekildi.

ID	Senaryo (kim → kapı → fiziksel sonuç)	L·S·E	Skor	Önlem → ilgili lab	Sorumlu	Kalan risk
S1	Eski vardiya amiri → paylaşılan Arma Mobil hesabı → yoğun saatte rastgele yükselt/indir → hattaki yaya ya da motosikletli	3·3·3	**27** Kritik	Kişisel hesap + MFA; mobil "aç" görevli onaylı, uzaktan "yüksel" yetkisi yok **LAB 2**; ayrılanın hesabı aynı gün kapanır; fotosel bypass kaldırılır, SF-1 Safety PLC'de **LAB 1**	Güvenlik müdürü + OT güvenlik	1·3·3 = **9** Yüksek
R4	Şoför ya da ziyaretçi → kulübe Wi-Fi (parola duvarda) → Arma Kart HTTP/80 varsayılan parola → loop hassasiyeti düşürülür, fotosel bypass kalıcı, gecikme 0 sn → günler sonra hattaki yaya/motosikletli	2·3·3	**18** Kritik	Wi-Fi Z5'e taşınır; Arma Kart parolası değişir; yapılandırma yalnız anahtarlı bakım modunda **LAB 2**; SF-1 parametreleri Safety PLC'de, imza/CRC izlenir **LAB 1**	OT güvenlik + entegratör	1·3·3 = **9** Yüksek
R5	Saldırgan → loop'a metal plaka bırakır (fiziksel kapı) → SF-1 bariyeri aşağıda tutar → düşmanca araç tank sahasına → patlama / zehirli gaz	3·3·2	**18** Kritik	Loop uzun süre doluysa alarm + kamerayla doğrulama; iç ve dış bariyer hattı aynı anda inemez (sas kilidi)	Güvenlik müdürü	1·3·2 = **6** Orta
S2	Organize grup → 433 MHz sabit kodlu RF → SDR ile kaydet ve gece tekrar oynat → bariyerler iner → patlayıcı yüklü araç tank sahasına	2·3·2	**12** Yüksek	Kayan kodlu / şifreli alıcı; RF yalnız "aç talebi" taşır, görevli onaylar **LAB 2**; sas kilidi (R5 ile ortak)	Güvenlik müdürü + entegratör	1·3·2 = **6** Orta
S3 ⚑	Zararlı yazılım (kilitsiz USB) ya da TeamViewer → kulübe PC → WOC → bakımda beklenmedik hareket → çukurdaki teknisyen	1·3·1	**3** Düşük ⚑ öne alındı	USB kilidi; TeamViewer yerine jump server **LAB 2 · LAB 4**; LOTO + anahtarlı bakım modu; yıllık tatbikat	İSG uzmanı + bakım şefi	1·3·1 = **3** ⚑ izlenir

Register'dan çıkan ders: Beş senaryodan ikisi (S2, R5) siberden değil, güvenlik–emniyet çatışmasından besleniyor. Bariyeri indiren her yol bir güvenlik açığı, yükselten her yol bir emniyet tehlikesi. Bu yüzden en çok riski düşüren tek önlem bir yazılım ayarı değil, mimari: SF-1'in ayrı Safety PLC'de olması ve iki bariyer hattı arasında sas kilidi.

G üreticinin sitesinde yazan bilgi · V eğitim senaryosu varsayımı, **Arma ürünü hakkında iddia değildir**. Puanlar bu hayali kurulum için ekip değerlendirmesidir; L/S/E ölçekleri 1. sayfada. Önlemlerin teknik ayrıntısı LAB 4 (güvenli uzak erişim) ve LAB 5'te (yama kararı) işlenecek.

Bu föyün çıktısı **Risk Register** → Evidence Pack **EP 04 Risk Assessment** başlığına oturur.